

Third-Party Software Secure Acquisition Plan

Cydney Goldstein

Table of Contents

<i>Purpose & Scope</i>	<i>3</i>
<i>Reference Documents</i>	<i>3</i>
<i>Supply Chain Risk Mitigation Considerations.....</i>	<i>4</i>
<i>Detailed Description of Supply Chain Risk Mitigation Controls</i>	<i>5</i>
<i>Implementation Priorities</i>	<i>8</i>
<i>Problem Reporting and Corrective Action.....</i>	<i>11</i>
<i>Tools, Techniques, and Methodologies Employed.....</i>	<i>13</i>
<i>Records Collection, Maintenance, and Retention</i>	<i>17</i>
<i>Training</i>	<i>21</i>

Purpose & Scope

Wild Blue Yonder Technologies is a general holding company with subsidiaries concentrated in developing advanced capability components with and for the United States Department of Defense. WBYT has contracted with the United States Air Force to upgrade the navigation system of the F16 aircraft with Advanced Global Positioning System (GPS) capability to improve flying conditions and in-air target pinpointing. Support is needed in integrating the GPS into the existing on-board navigation system, display said information in the Head-Up Display (HUD), allow pilot access to modified navigation data through the Control Display Unit (CDU), and communicate all GPS information back to ground control or mission-sensitive aircraft. The GPS/CDU software is already implemented in the United States Army AH64D Apache Longbow helicopters and because of this, is considered an off-the-shelf product. The software developers are subsidiaries within WBYT, however, are located offshore.

This Third-Party Software Secure Acquisition Plan defines the controls, governance expectations, and supply chain risk management activities required for Wild Blue Yonder Technologies' GPS/CDU upgrade project for the United States Air Force. The project involves integration of a modified COTS GPS capability into the F-16 navigation environment and development of an updated Control Display Unit, with approximately 29,000 total source lines of code affected across both workstreams.

Reference Documents

[DoD 5220.22-M \[Department of Defense Instruction Document on Data Sanitization\]](#)

[ISO/IEC 12207-2008: Systems and Software Engineering- Software Life Cycle Processes](#)

[ISO 15408-1: 2022: Information Security, Cybersecurity and Privacy protection – Evaluation Criteria for IT Security](#)

[NIST 800-30: Guide for Conducting Risk Assessments](#)

[NIST 800-53: Security and Privacy Controls for Information Systems and Organizations](#)

[NISTIR 7622: Notional Supply Chain Risk Management Practices for Federal Information Systems](#)

Supply Chain Risk Mitigation Considerations

Because the GPS/CDU upgrade is a life-critical acquisition involving COTS reuse, subcontracted software modification, formal documentation requirements, and moderate visibility needs across the supply chain, Wild Blue Yonder Technologies must implement a structured set of supply chain risk mitigation controls across software assurance, supplier governance, change management, media handling, and continuous oversight. These controls are intended to reduce the likelihood that insecure, unverified, or poorly governed software components enter the F-16 environment while also improving management visibility, auditability, and compliance with ISO/IEC 12207:2008, NIST SP 800-30, NISTIR 7622, and relevant NIST SP 800-53 control expectations.

Code Integrity and Software Assurance

All third-party and subcontracted code associated with the GPS/CDU project shall be subject to formal integrity verification before acceptance, integration, or release into any test or production-equivalent environment. This is especially necessary because WBYT has previously identified Trojan code in overseas COTS products and because the GPS modification effort will be performed by a subcontractor whose supply chain must be vetted alongside WBYT's own processes.

Configuration and Change Management

WBYT currently lacks software configuration management across the supply chain, creating risk around unauthorized changes, poor version visibility, weak rollback capability, and inconsistent oversight of subcontractor modifications. To address this, WBYT shall establish a formal Software Configuration Management process for the GPS/CDU program covering internally

developed code, modified COTS components, interface documentation, test artifacts, and supplier-delivered software baselines.

Media Security and Handling

Because the GPS/CDU effort involves life-critical software, formal documentation, subcontractor deliverables, and defense-related information, WBYT must protect both digital and physical media from tampering, unauthorized access, loss, and improper disposal throughout the acquisition lifecycle. Media security controls shall apply to source code packages, documentation, design records, test results, assurance case materials, change logs, supplier reports, and any removable media or transport mechanism used in support of the project.

Supplier Vetting and Oversight

Supplier risk management for the GPS/CDU project shall begin before contract award and continue through development, testing, integration, delivery, and post-development support. This is necessary because the GPS software modification will be performed under subcontract, WBYT has a history of concerns involving overseas COTS security, and the case specifically requires stronger supply chain risk management under a NIST 800-53-driven environment.

Continuous Monitoring

Continuous monitoring is required to ensure that supply chain risk controls remain effective throughout development, integration, testing, and support rather than only at the point of procurement. WBYT already collects useful security and defect metrics, but the case notes that these metrics remain largely at the project level and do not provide sufficient visibility to upper management or the broader organization. For this project, continuous monitoring shall correct that gap by integrating supplier, software, and operational indicators into a formal governance process.

Detailed Description of Supply Chain Risk Mitigation Controls

Given the critical and classified nature of the project, Wild Blue Yonder Technologies must

acknowledge all risks associated with each level of the product supply chain. WBYT has run into issues involving past utilization of COTS products and offshore third-party vendors, posing large security risks for their clientele. It is essential that multi-layered and holistic security controls be implemented to ensure integrity, authenticity, and compliance of all involved components of this project.

- **Code Integrity Assurance:** All source code provided by third-party vendors is to be formally verified. This involves:
 - Mandatory digital signatures and PKI-based cryptographic verification
 - Formal Software Bill of Materials (SBOM) for each component.
 - Mandatory code reviews of all SLOC to identify potential backdoor infiltrations:
 - Aligned with:
 - ISO/IEC 27001 A.15.1.1, A.15.1.2
 - NIST 800-30 (Risk assessment of software vulnerabilities)
 - NIST 800-53 SR-3, SR-5
 - NISTIR 7622 (Supply chain transparency)
- **Configuration and Version Control:** Implementation of a centralized Software Configuration Management framework. This involves:
 - Logging of all code changes
 - Secure storage and rollback mechanisms of all version controls
 - Automated security testing with rapid vulnerability detection
 - Prevents unauthorized modifications
 - Aligned with:
 - ISO/IEC 12207: 2008 (Configuration management)
 - NIST 800-30 (Continuous monitoring)
 - NIST 800-53 CM-3, CM-8
- **Secure Digital Media Transfer and Storage:** Protection of all digital media involved in the project to protect the project against tampering. This involves:
 - Software Configuration/design documents
 - Software test results

- Usage of centralized repositories with federally mandated AES-256 encryption standards.
- Aligns with:
 - ISO/IEC 12207:2008 (Records management)
 - NIST 800-30 (Risk mitigation for data in transit)
 - NIST 800-53 SC-12, SC-13
- **Physical Media Sanitization and Secure Disposal:** Physical media within all levels of supply chain must undergo sanitization protocols before disposal to prevent data compromise.
 - Aligns with:
 - DoD 5220.22-A
 - ISO/IEC 12207:2008 (Secure handling of physical records)
 - NIST 800-30 (Physical security controls)
 - NIST 800-53 MP-6
- **Supply Chain Backdoor Prevention:** Enforcement of a formal supply chain risk management policy. This includes:
 - Mandatory Software Bill of Materials for each vendor supplied component.
 - Rigorous code reviews with corresponding documentation
 - Sandbox testing for all vendor software before integration
 - Requirement that all third-party vendors are to be audited by WBYT
 - Aligned with:
 - ISO/IEC 27001 A.15.1.1, A.15.1.2
 - NIST 800-30 (Supply chain risk assessment)
 - NIST 800-53 SR-3, SR-5
 - NISTIR 7622 (Vendor risk management practices)
- **Comprehensive Supplier Vetting and Auditing:** Prior to the contract acceptance and periodically thereafter, evaluate each third-party vendor using a formal risk assessment framework. This includes:
 - Due diligence and company background checks

- Mandating security requirements as per ISO/IEC 12207:2008
- Enforce direct integration of vendor incident reports with WBYT's newly developed software configuration management system.
- Aligned with:
 - ISO/IEC 12207:2008 (Supplier management processes)
 - NIST 800-30 (Ongoing risk monitoring)
 - NIST 800-53 SA-12, CA-7
 - NISTIR 7622 (Continuous supplier oversight)
- **Ongoing Monitoring and Performance:** Implement periodic third-party vetting and continuous monitoring. This includes:
 - Tracking KPI's such as remediation times and audit compliance scores
 - Supplier adherence to security protocols and compliance standards regulated under contract
 - Aligned with:
 - ISO/IEC 12207:2008 (Continuous process improvement)
 - NIST 800-30 (Performance-based risk monitoring)
 - NIST 800-53 CA-2, CA-7
 - NISTIR 7622 (Supplier performance metrics)

Implementation Priorities

Implementation priorities for the GPS/CDU secure acquisition effort are to be based on mission impact, life-safety implications, supplier dependency, and WBYT's current control weaknesses. Because the project involves modified COTS software, a subcontracted GPS supplier, formal government documentation, five interfaces, and long-term operational support, WBYT must implement controls in a staged manner that first establishes governance and integrity, then strengthens visibility and sustainment.

Priority 1: Establish Foundational Governance and Control

The first implementation priority shall be the creation of the formal management structure needed to control the acquisition before additional software integration progresses. This

includes immediate development and approval of the Software Risk Management Plan, Software Configuration Management Plan, Software Assurance Plan, and related compliance agreements so that WBYT can correct its current lack of software configuration management, weak review culture, and informal reporting practices. Because the case states that most reporting currently occurs in the form of rumor rather than objective data, WBYT must first establish formal reporting channels, approval authorities, escalation paths, and review ownership across internal teams and subcontractors. At this stage, WBYT shall also define the governance structure for supply chain oversight, including the role of the project manager, risk manager, software assurance personnel, configuration control authority, and supplier management representatives. Without these foundational controls, later technical security measures would be inconsistently applied and difficult to audit.

Priority 2: Secure the Supplier and Incoming Software

The second implementation priority shall be supplier vetting and code integrity assurance for the subcontracted GPS modification effort and any other sourced components. This is critical because WBYT has previously discovered Trojan code in overseas COTS products, and the case explicitly states that the subcontractor's supply chain must be vetted along with WBYT's own. Before accepting supplier software or documentation, WBYT shall require due diligence reviews, documented contractual security requirements, source provenance validation, software bill of materials submission, and formal acceptance criteria for all incoming deliverables. This phase shall also include the introduction of secure intake procedures for supplier code, interface documentation, and software updates. All externally supplied components shall be scanned, reviewed, logged, and approved before they are permitted into the integration environment, reducing the risk that malicious or defective code enters a life-critical aircraft system.

Priority 3: Implement Configuration and Change Management

The third implementation priority shall be the deployment of a formal configuration and change management capability across the full GPS/CDU lifecycle. The case identifies the absence of software configuration management at any level in the supply chain as a major organizational

weakness, making this one of the most urgent operational fixes. WBYT shall therefore establish baselines for source code, interfaces, requirements, design artifacts, test materials, and supplier submissions, with every change linked to approval records, security review results, and version history. This priority is especially important because the project involves modifications to an existing navigation environment, new CDU development, and multiple interfaces that must be carefully controlled throughout the effort. Strong configuration control will allow WBYT to maintain traceability, prevent unauthorized modifications, and support rollback, auditing, and release integrity across both internal and supplier-developed components.

Priority 4: Formalize Reviews, Metrics, and Management Visibility

The fourth implementation priority shall be to move WBYT from project-level tracking to organization-level visibility through documented reviews, metrics governance, and reporting processes. The case makes clear that WBYT already collects useful security and software metrics, but those measures are not consistently shared upward and do not provide adequate visibility to program leadership or upper management. WBYT shall therefore implement formal in-process reviews, recurring assurance reviews, defect and incident reporting dashboards, and defined procedures for distributing relevant metrics internally and, where required, to the acquisition organization. This step is necessary not only for governance but also for compliance with the documentation-heavy nature of the project and the need to show that all identified risks are being actively mitigated. By formalizing reviews and reporting, WBYT can replace rumor-based communication with defensible evidence tied to configuration baselines, test outcomes, and supplier performance.

Priority 5: Strengthen Testing, Media Security, and Long-Term Support

The fifth implementation priority shall focus on sustainment-oriented controls that ensure the project remains secure through testing, deployment, transition, and post-development support. Because the application is life-critical, WBYT must place strong emphasis on reliability-focused testing, secure handling of project media and documentation, and preparation for transition to government support environments. This includes protecting code and documentation in transit and at rest, sanitizing physical media appropriately, retaining records for audit and support

needs, and maintaining evidence needed for the assurance case and qualification activities. This phase also supports the long-term service life of the upgraded aircraft and the project's extensive documentation obligations. Once foundational governance, supplier control, configuration management, and formal reviews are in place, WBYT will be in a stronger position to sustain secure operations over time rather than relying on one-time compliance activity.

Problem Reporting and Corrective Action

The successful integration of the GPS/CDU software into the F-16 navigation system is dependent on WBYT's ability to proactively identify, report, and address problems that occur within the secure acquisition process. Likewise, third-party vendor compliance with problem reporting and corrective action policies is required. In previous projects, WBYT has come across issues such as software defects and security vulnerabilities from working with off-shore COTS products. Such vulnerabilities were reported informally, making proper management unaware of the complexity of the situation. Gaps in formal reporting can lead to delayed corrective action which can be detrimental to secure software acquisition processes. Therefore, it is critical that a robust framework be established to handle all problems, whether it be from WBYT or third-party vendors, to be handles with the utmost efficiency. The following approach aligns with objectives outlined in ISO 12207:2008, NIST 800-30, and NISTIR 7622 .

- WBYT Reporting
 - Baseline: WBYT gathers project-level metrics such as reported defects and threat occurrences but does not report them to management or only informally makes management aware. Although these metrics are tracked daily, there is no option for organizational visibility. Informal reviews and ad hoc reporting create an inconsistent environment as to how issues are escalated.
 - Reporting Improvement Procedures:
 - o Centralized Reporting Dashboard and Framework: The development of a formal and centralized reporting dashboard and framework will provide a standard for every level of project personnel to have access to any issue. This dashboard will log software defects, configuration inconsistencies, and any

gaps found in security. This system is to integrate into the software configuration management tools to link reported issues with specific software source lines of code or versions.

- Automated Defect Tracking: The deployment of an automated defect tracking system (such as an SIEM) will automatically elevate critical incidents to proper senior management. This will ensure all issues identified are logged and flagged for review.
- Regular Review Meetings: Project teams are to implement regular review meetings with all prominent personnel present, including upper management. These meetings will assess the status of reported problems, track resolution progress, and adjust risk mitigation strategies in an open and systematic way. These sessions should include representatives from software engineering, software assurance, procurement, and supplier oversight.
- Third-Party Vendor Reporting
 - Baseline: Each third-party vendor manages its own defect tracking. Problems that are emerging in third-party vendor supplied code have delayed corrective action due to a lack of reporting structure.
 - Reporting Improvement Procedures:
 - Vendor Reporting Requirements: During the initial development of the contract between WBYT and the third-party vendor, it should be made clear that third-party vendors are to submit problem reports to WBYT. These reports are to include detailed logs of all software modifications, security vulnerabilities identified, and actions taken by the vendor. These reports are to be sent to teams at WBYT and then integrated into their software configuration management system for traceability.
 - Vendor Problem Escalation Protocols: During the initial development of the contract between WBYT and the third-party vendor, it should be established that strict escalation procedures need to be enforced; otherwise, the contract is in jeopardy. Problem reporting must be escalated to proper WBYT

managers immediately. WBYT- run audits and supply chain compliance reviews will enforce this.

- WBYT Corrective Action Improvement Procedures:
 - Standardized Problem Resolution: Established standardized problem resolution procedures. This includes assigning project severity levels, determining the root cause and setting resolution deadlines.
 - Cross-Functional Team Formation: Create cross-functional teams in the case of an immense problem. These teams are to include representatives from software engineering, software assurance, and supplier management. In collaboration, these teams can conduct root-cause analysis of any issue, recommend corrective actions, and ensure that everything is documented and logged within the software configuration management system.
 - Continuous Monitoring: Utilize newly established software analytics to track recurring issues and adjust measures to provide proactive corrective action.
- Third-Party Vendor Corrective Action Improvement Procedures:
 - Solution Deadlines: Mandate deadlines for problem solutions expected from third-party vendors. If a vulnerability is reported, third-party vendors are required to submit a plan of corrective action with strict adherence to deadlines. Failure to meet set deadlines could invoke penalties as specified within the vendor's contract.
 - Vendor Audits: Conduct periodic vendor audits to verify that corrective actions have been implemented effectively. Also, use this time to ensure every problem reporting document is logged and integrated into the software configuration management system framework.

Tools, Techniques, and Methodologies Employed

Effective security in acquisition at Wild Blue Yonder Technologies requires the utmost comprehensive control and governance, due to the nature of the product at hand. Ensuring that the integration of the new GPS/CDU system stays within federal and Department of

Defense regulations will safeguard defense systems from cyber threats, unauthorized modifications, and all other vulnerabilities. Having complete governance over WBYT as well as all third-party suppliers involved as a multi-layered approach will secure the future of WBYT's high-tech defense contracts. It is necessary that WBYT balances cost-effectiveness with strict security and governance policies, particularly when sourcing COTS and GOTS software from third-party vendors. As acknowledged, WBYT has had previous security run ins with Trojan code embedded in overseas COTS products, highlighting a need for robust security vetting, continuous risk monitoring, and controlled procurement protocols. Additionally, WBYT has a decentralized supply chain that presents multiple vulnerabilities, indicating a need for a stricter supply chain governance framework. To address the risks at hand, WBYT shall employ a structured framework across code control, media control, and supplier control, to contribute to the development of the entire supply chain.

Code control

- WBYT Baseline:
 - Although it is established that Wild Blue Yonder Technologies has a well-defined process for all software development in-house, it can be deduced that risk management processes are a weak point within their framework. In addition, upper management lacks visibility into software development, vulnerabilities, and metrics, leaving lower-level analysts and engineers to attack the problem on their own. There is no formal software configuration management at any level of the supply chain, raising risks for code integrity, version control, rollback processes, etc. There is no formal reporting to superiors in the case of a threat.
- Third-Party Vendor Baseline:
 - As far as third-party vendor security and supply chain management are concerned, there have been incidents in the past regarding the security of COTS products procured by WBYT. Although COTS products go through vetting processes to ensure safety upon initial procurement, code control is not modulated through security updates from the third-party vendor.
- Secure Code Acquisition and Control

- Secure Development and Verification: In compliance with ISO 12207-2008 and NIST 800-53, a software development procurement plan is to be drafted. This will ensure a rigorous documentation trail and will secure implementation of modifications. This is to be agreed upon by all third-party vendors as well as WBYT, to ensure documentation is noted across the entire project.
- Source Code Vetting: All 29000 source lines of code are to go through a code provenance analysis before integration through the in-house teams at WBYT. This will detect any potential vulnerabilities or embedded threats.
- Automated Testing Integration: Both static and dynamic tools (SonarQube and Fortify as examples) will be integrated throughout the software development process to detect vulnerabilities in pre-deployment.
- Software Configuration Management: Before deployment, a software configuration management plan will be developed for the GPS/CDU system. This framework provides instruction for pre-, during, and post-development. It will provide instruction for version control management, change management and approval, compliance/audit tracking, access control, security assurance, and metrics/reporting.

Media control

- WBYT Baseline:
 - It is noted that WBYT tracks the following metrics: frequency of threats identified, number of security incidents, costs of security incidents, staff incidents, and number of software defects. These metrics are used for internal security planning but are not shared with stakeholders or government partners. Metrics are not tracked and reported to proper authorities, indicating there may be an issue with unauthorized modifications in media transfers that could go undetected.
- Third-Party Vendor Baseline:
 - Due to the issue with the identified Trojan code in acquired software, there is a rise in concern with unverified media sources. Subcontractors handle their own media assurance policies, indicating WBYT does not have a hand in third-party vendor

security audits. It is written in contracts between WBYT and third-party vendors that there is a mandated compliance with security controls, but continuous monitoring remains a challenge.

- Secure Media Handling in Acquisition:
 - Digital Signing and Encryption: For complete media control, all software acquisitions are to undergo PKI-based code signing. The use of digital certificates and cryptography will verify the integrity and authenticity of the software before integration.
 - Controlled Transfer Mechanisms: Media repositories are to be secured with least privilege access, providing protection from unauthorized alteration of all GPS/CDU components.
 - Media Sanitization: All related documents to the case are to be sanitized following the DoD 5220.22-M standards for proper disposal post-development. This ensures future contracts between WBYT and the Department of Defense.
 - Supply Chain Documentation: All media involved in procurement of the third-party vendor's compliance, as well as their COTS product is to be tracked and logged for auditing. This provides a paper trail to reaffirm security throughout the acquisition lifecycle.

Supplier control

- WBYT Baseline:
 - All supplier and acquisition decisions are centralized within WBYT's New York headquarters. This is to confirm policy alignment and financial oversight. Due to past experience with COTS products containing embedded Trojan code, WBYT prioritizes supplier validation and in-house development control over all security measures. There is a gap in third-party supplier governance by WBYT.
- Third-Party Vendor Baseline:
 - The third-party vendor of the GPS/CDU system operates independently with security modifications falling under the supplier, rather than WBYT. Each subcontractor is responsible for their own security standards and compliance. There is no direct

supply chain mandate by WBYT beyond the initial contract. Overseas sourcing is known to arise security concerns.

- Secure Supplier Control in Acquisition:
 - Development of Secure Procurement Contracts: Upon the initial contractualization between WBYT and the third-party vendor, agreements are to be made regarding standardized compliance measures. These are to fall within the Department of Defense and the United States federal compliance documents. These contracts will also mandate regular security audits of the third-party vendors by WBYT, as well as compliance testing.
 - Third-Party Vendor Risk Assessments: Using the framework provided by NISTIR 7622, supplier security maturity will be evaluated before the acquisition of the software.
 - Vendor Access Controls: Vendors are granted least privilege access to proprietary systems pertaining to the project. Everything presented to vendors is on a need-to-know basis, procuring the security and compliance measures expected of a subcontractor of the United States government.
 - Continuous Monitoring: Adherence to NIST 800-30 is necessary for ongoing risk management.

Records Collection, Maintenance, and Retention

For Wild Blue Yonder Technologies to ensure compliance and operational oversight in a secure acquisition process, effective record management is integral. Since WBYT has a decentralized business model and subsidiaries handle critical technology products, it is necessary for a standardized records framework to be established. Since there have been previous concerns in regard to third-party COTS products and their security, WBYT must strengthen their record keeping processes and exposure. It is also noted that WBYT does not have effective problem reporting procedures, as many problems are treated as “rumors” and only spoken, not recorded. This is yet another issue that requires fixing to achieve an effectively flowing business model. Reworking the record keeping processes will provide visibility into project performance for managers and stakeholders, improve third-party vendor security measures, and track

compliance for audits. Every record between both WBYT and any third-party vendor must comply with Department of Defense standards, NIST 800-53, and ISO 12207-2008.

Record Collection

- WBYT Record Collection
 - Baseline: Wild Blue Yonder Technologies tracks key security metrics related to acquisition and risk management. However, these metrics are not used as effectively as possible, as they are managed at the project level rather than at the organizational level. These records include frequency of threats identified, number of security incidents, costs of security incidents, staff incidents, and number of software defects.
 - Essential records to track:
 - Software Development Documentation: Compliance with ISO 12207-2008 requires extensive technical records such as Software Requirement Specifications and Assurance Case Documentation. Keeping these records will protect the secure acquisition process in the case of an internal or federal audit.
 - Security Incident Metrics: Standardize collection of data compiled into a security dashboard for management and stakeholder access. Incident metrics are to include: Threat projections, software defects, repair statistics, downtime, rollback tests, etc.
 - Software Assurance Testing Results and Audit Integration: Although WBYT performs defect tracking and software inspection, a formal audit and recording process is lacking. Audit framework, such as a scheduled meeting and documentation framework, should be integrated to ensure validity in product development. This is across WBYT as well as with representatives from third-party vendors.
 - Third-Party Vendor Contract Agreements: All third-party vendor agreements should document security requirements, liability clauses, and software assurance obligations. In addition, a monthly report pertaining to the

supplier's continuous monitoring processes, any threat detection, downtime detection, and other agreed upon security measures. This will allow upper management at WBYT to have insight into the third-party supplier's security framework in case there is an infiltration via software components.

- Third Party Vendor Record Collection
 - Essential Records to Track:
 - Third-Party Vendor Risk Assessments: Each third-party supplier should have written in their initial contract that compliance and proof of compliance with NISTIR 7622 is required to work with WBYT. Risk assessment reports, security validation testing, and supply chain security documentation should be submitted to WBYT once a month to monitor third-party compliance.
 - Software Vetting: Vendors must run and provide source code analysis in order to submit reports to reporting individuals at WBYT. This ensures regularly that third-party modifications to the GPS/CDU system do not introduce Trojan code or other vulnerabilities into a software representative of WBYT.
 - Development Logs: Due to the nature of the GPS/CDU project and its sensitivity, it is required that vendors submit development logs, test reports, and compliance certificates, so WBYT has them for reference.

Record Maintenance

- WBYT Record Maintenance
 - Baseline: Software configuration management is lacking within WBYT, as all software modifications are not tracked. Records remain within individual projects instead of being known organization-wide. WBYT has a weak review culture, often leaving upper management out of the loop. Although software engineering modifications are made aware to the Vice President of Engineering, it is shared via informal conversation, rather than an established submitting system.
 - Maintenance Measures:
 - Centralized Record Database: All records should be maintained within a

centralized dashboard maintained within WBYT's global network. This is to contain encrypted access controls and role-based access management.

- Software Configuration Management System: Within the dashboard, there should be a developed software configuration management system and framework. This is to track all code modifications and supplier security data in an organized framework.
- Quarterly Security Submit Review: During WBYT's quarterly security summits moving forward, all acquired supply acquisition security records should be reviewed. This will promote awareness among subsidiary site managers about emerging risks within the GPS/CDU project.
- Third-Party Vendor Record Maintenance
 - Maintenance Measures:
 - Supplier Compliance Monitoring: Upon initial contractualization, it is to be required that all third-party vendors maintain a historical security documentation for long-time reference. This includes all software test results or records of maintenance deployment.
 - Audit Trails: All third-party interactions with WBYT are to be logged and monitored through Security Information and Event Management (SIEM) tools. This ensures proper oversight and problem reporting tracking.

Record Retention

- WBYT Record Retention
 - Baseline: There is no formal configuration management system used to systematically store software modifications governing record retention. It is necessary that there is a long-term retention of all acquisition-related records to ensure compliance and enforce security practices, especially because GPS/CDU integration is a long-term project. It is necessary that every record, from WBYT acquisition to third-party vendor supply, comply within NIST 800-53 and ISO 12207-2008.
 - Retention Measures:

- Long-term Documentation Storage: This project is in collaboration with aircraft development within the United States Government. Software rollout is predicted within a timeline lasting 3.25 years, with usage predicted to last multiple decades. Long-term storage of every document within an established security dashboard is required for reference.
- Encrypted Archives: Within the long-term storage, it is required that all classified documents pertaining to the software acquisition must be stored using the federally mandated AES-256 encryption, restricting access to certified personnel only.
- Third-Party Vendor Record Retention
 - Retention Measures:
 - Supplier Contract Records: It is required that all third-party vendors safeguard and make accessible all contract records between themselves and WBYT, so that if need be, certified employees may access for reference.
 - Software Security Reports: Third-party vendors must retain all formal security validation reports for at least five-years post delivery. This is to ensure accountability among the entire participating vendor in regard to security assurance.
 - Compliance Records: In case of audit, all security breaches, patch updates, and compliance failures are to be archived indefinitely. This is to support any potential legal proceeding should there be a forensic investigation or a federal audit.

Training

Ensuring the secure acquisition and integration of software components into the GPS/CDU project requires specialized training with all involved parties. Due to the nature of the project dealing with compliance with the Department of Defense and the United States Air Force, there are multiple federal regulations that provide the framework for personnel across the entire procurement process. Standards such as those provided in NIST 800-30 will provide training

processes for WBYT and its third-party vendors to become accustomed to.

Training Objectives

The purpose of this training program is to focus on enhancing awareness and operational compliance within supply chain security for the procurement of the GPS/CDU upgrade. All training is to align with ISO 12207-2008 (Systems and Software Engineering- Software Life Cycle Processes), NIST 800-30 (Guide for Conducting Risk Assessments), and NISTIR 7622 (Notional Supply Chain Risk Management Practices for Federal Information Systems). Taking from training standards provided by this documentation, a framework can be developed. WBYT's GRC team can begin the development of the training process by becoming accustomed to compliance with regulations.

In regard to choosing a third-party vendor, it is necessary that appropriate staff become trained in conducting supplier risk assessments. This ensures that all third-party vendors comply within noted security mandates, and do not pose a risk working with WBYT. Personnel are explicitly to be taught to identify and mitigate risks associated with international COTS product procurement. It is also recommended that personnel is provided the knowledge of normal third-party vendor dependencies. Informing personnel of what is to be provided by third-party vendors and what is not, will provide off-hand abilities to acknowledge any discrepancies. It is also required that third-party vendors be made aware of media security, encryption standards, and document retention processes that WBYT requires as per their contract.

Personnel are also to be trained on automated security testing tools and GOTS products that are to be utilized during this project (such as SonarQube or Fortify). This will detect third-party source code vulnerabilities and protect the software at hand during every stage of development.

Training Modules

WBYT is to implement a structured training curriculum, which is divided into modules that are tailored to personnel roles and access levels.

- Procurement and Supplier Management

- Audience: Acquisition managers, third-party vendor vetting teams.
- Reference Documents: NISTIR 7622
- Topics
 - Contractual Security Standards: Each member will be aware of every standard provided or to be provided to the third-party vendor as per the written contract.
 - Access Control Models: Each member will be aware of the established access control models to minimize third-party risk exposure.
 - Identifying and Preventing COTS Product Security Vulnerabilities: Each member will be aware of how to prevent and identify security vulnerabilities within COTS software. This includes training on continuous monitoring systems.
- Software Assurance and Configuration Management
 - Audience: Software engineers, project managers, software assurance teams.
 - Reference Documents: NISTIR 7622
 - Topics
 - Static and Dynamic Code Analysis Tools: Each member will be provided training in tools such as SonarQube and Fortify so code analysis can be implemented regularly.
 - Secure Configuration Management: Each member will be aware and provided training in the newly established software configuration management protocols.
 - Cryptographic Controls: Each member will be tested to prove their knowledge or given training in secure code-signing and all authentication mechanisms.
- Data Protection Training
 - Audience: IT administrators, cybersecurity teams, operations personnel.
 - Reference Documents: NISTIR 7622; DoD 5220.22-M
 - Topics:

- Media Transfer Protocols: Each member will be provided training and will have to prove knowledge of newly established encryption and data sanitization standards.
- Security Information and Event Management (SIEM): Each member will be provided training in the SIEM that will be conducting all media tracking.
- Incident Response Strategies: Each member will be given training in incident response strategies, as well as proper methods of vulnerability reporting.

Training Implementation and Evaluation

In order to ensure WBYT is providing effective training, it will be necessary that an established certification program is implemented. Using the framework provided above, role-based certifications will be awarded to those who complete their training. These certifications are to be completed using designed Moodle modules, containing resources, reference documents, interactive videos, and summary quizzes. Regular audits will verify adherence to training outcomes by department, ensuring that all personnel has correctly adhered to organizational-wide training guidelines. Simulated security threats are also to be implemented once a year to view supply chain vulnerabilities, software assurance failures, and operational continuity.

Although WBYT has a quarterly security summit already implemented in regular operations, it is imperative that the content of this summit be updated. These summits are to now include quarterly security refreshers, allowing personnel to address emerging security risks and if there are any compliance challenges.

In order to maintain these levels of training, mandatory onboarding training will be required for all acquisition and software assurance personnel. This will allow initial certification to be awarded based on personnel experience prior to joining the program, and will demonstrate areas personnel may need further training in. Quarterly security evaluations will be reinforcing compliance regulations and adapting training to ever-evolving threats. Finally, there will also be annual certification renewal requirements to maintain proficiency in secure acquisition practices.

